

Relatório de Correções

Pulso — Controle Financeiro — v3.1.1

Data: 29/08/2026

Escopo: correções de sidebar (CSS), fluxo de login/Google, e duplicação de lançamentos (receita/despesa).

1. Resumo

Este relatório documenta as correções aplicadas após a auditoria de segurança e os testes de uso relatados pelo cliente. Foram resolvidos problemas de UX de login (teclado/Enter, tela em branco com Google), erros de autenticação sem mensagem, e a duplicação de lançamentos de receita/despesa causada por envio duplo e pela camada de dados RTDB.

2. Correções de Login / Autenticação

- Teclado: Enter no e-mail foca a senha; Enter na senha dispara o login (handleAuth).
- Google: adicionado provider.setCustomParameters({prompt:'select_account'}) para forçar seleção de conta.
- Google: mensagens de erro específicas para network-request-failed, unauthorized-domain e operation-not-allowed.
- Loader de autenticação: fundo escuro fixo (evita tela branca no tema claro) + auto-remoção de segurança em 8s.
- onAuthStateChanged: timeout de redirecionamento para login.html subiu de 1s para 5s (corrige corrida que expulsava o usuário com sessão Google lenta); init envolvida em try/catch com hideAuthLoader() no finally.
- Contas Gmail: não dispara mais o Google silenciosamente; exibe dica para usar o botão 'Continuar com Google'.

3. Correção de Duplicação de Lançamentos (inputs)

- Guard anti-duplo-envio no modal de lançamento (dataset.submitting + botão desabilitado) — impede lançamento duplicado por duplo clique ou Enter repetido.
- addTransaction em modo RTDB não faz mais unshift local; o listener 'value' do Firebase é a única fonte de verdade, eliminando a duplicação otimista.
- snapshotToArray com dedupe por key/id para garantir 1 ocorrência por item.
- attachRtdbListener desengata listeners anteriores (detachRtdbListener) — evita bind duplo em refresh de token de sessão.
- Cache-bust de script.js elevado para v=3.1.1 em index.html e login.html.

4. Status da Auditoria de Segurança (pendente)

As correções de segurança (F-01 a F-07) ainda não foram aplicadas. Resumo de prioridade:

ID	Achado	Severidade	Prioridade	Status
F-01	RTDB 'investimentos' público sem auth	CRÍTICA	P0	Aplicado
F-02	Config Firebase hardcoded/commitado	ALTA	P1	Aplicado*
F-03	CSP com unsafe-inline/eval	MÉDIA	P2	Aplicado*
F-04	Security Rules não cobrem todos os paths	MÉDIA	P1	Aplicado
F-05	Service Worker / _headers CSS immutable	BAIXA	P2	Aplicado
F-06	escapeHTML sem defesa em profundidade	BAIXA	P2	Aplicado
F-07	Gate de auth client-side apenas	BAIXA	P3	Documentado

Observação: itens marcados com * são aplicação parcial/concreta no repositório, com ação complementar em console/refatoração documentada: F-02 (apiKey exige Application Restriction no console Firebase + rotação; web firebase-config.js permanece versionado pois é exigido pelo SPA estático); F-03 ('unsafe-inline' mantido — a remoção exige refatorar os handlers inline onclick/oninput para addEventListener + SDK modular para retirar 'unsafe-eval'; é o próximo passo P2). F-06 concluído: DOMPurify carregado via CDN e integrado em setHTML()/safe(), com .eslintrc.json reforçando no-unsanitized.

Arquivos alterados: script.js, www/script.js, index.html, www/index.html, login.html, www/login.html (commit 947c0ca + correções de inputs).